

Actividad 01: Análisis y planificación del pentest

Francini Quesada Chacón

Hacker Woman Council

1. Objetivo del Pentest

- Objetivo 1. Determinar el origen del incidente.

Confirmar si el reporte del cliente que visualizó información de otra cuenta corresponde a una vulnerabilidad real, delimitando su alcance real e impacto sobre los datos de clientes.

- Objetivo 2. Identificar y priorizar vulnerabilidades explotables en la aplicación.

Evaluar la autenticación, autorización, gestión de sesiones, validación de entradas y lógica de negocio, obteniendo una visión objetiva del nivel de riesgo actual frente a atacantes externos e internos.

- Objetivo 3. Entregar una hoja de ruta de remediación accionable.

Proveer al equipo de desarrollo un informe con hallazgos documentados, evidencia de explotación, severidad y recomendaciones priorizadas, permitiendo tomar decisiones informadas sobre inversión en seguridad y plazos de corrección.

2. Alcance

SÍ SE EVALUARÁ:

- Aplicación web como el registro, login, catálogo, carrito, checkout, historial de pedidos.
Gestión de productos, usuarios y pedidos.
- API que sustenta la aplicación web.
- Mecanismos de autenticación, autorización y gestión de sesión.
- Controles de acceso entre cuentas de usuario.
- Base de datos, únicamente en la medida alcanzable a través de fallos de la app.

FUERA DE ALCANCE

- Redes sociales corporativas de Aurora Market.
- Equipos y dispositivos personales de empleados.
- Cuentas de correo corporativo e ingeniería social sobre el personal.
- Proveedores externos salvo acuerdo explícito.
- Ataques de denegación de servicio.
- Modificación, borrado o exposición pública de datos reales de clientes.

3. Autorización y Condiciones

Permisos requeridos

- Autorización formal por escrito firmada por un representante legal de Aurora Market.
- Alcance documentado de dominios, aplicaciones y funcionalidades incluidas.
- Ventana de tiempo autorizada, coincidente con los horarios de menor actividad, con fecha de inicio y fin definidas.
- Acuerdo de confidencialidad para el manejo de la evidencia y de cualquier dato accedido durante las pruebas.

Condiciones acordadas

- No interrumpir el funcionamiento de la plataforma ni afectar la disponibilidad del servicio.
- No alterar o exfiltrar de forma permanente ni exponer información real de los clientes.
- Restringir todas las acciones al alcance acordado.
- Ejecutar las pruebas dentro de los horarios de menor actividad definidos por la empresa.
- Notificar de inmediato a Aurora Market ante cualquier hallazgo crítico o evidencia de que el incidente reportado corresponde a un compromiso ya ocurrido.
- Documentar toda la evidencia de forma controlada y entregarla o destruirla según lo pactado al cierre del proyecto.

4. Tipo de Pentest

Tipo elegido: GRAY-BOX.

Justificación de la elección

La empresa Aurora Market entrega un objetivo junto a una autorización formal y un alcance definido, comparte que existen una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuario, pero no entrega documentación técnica completa sobre la arquitectura ni las tecnologías utilizadas.

5. Planificación Previa:

1. Los objetivos mencionados anteriormente, deben estar validados y aceptados por Aurora Market.
2. Documento firmado que delimite sistemas incluidos y excluidos.
3. Rules of Engagement firmadas, NDA, credenciales de prueba y contacto de emergencia.
4. Se utilizará OWASP Testing Guide como referencia para las pruebas de aplicación web.
5. Revisar la documentación entregada por Aurora Market y complementar con reconocimiento propio antes de las pruebas activas.
6. Entorno de pruebas, herramientas y el equipo asignado con roles definidos.
7. Hacer el cronograma acordado con fechas y horarios de ejecución dentro de las ventanas de menor actividad, incluyendo tiempo reservado para el informe final.

6. Fases del Pentest Aplicadas al Caso

Fase 1 — Reconocimiento

Identificar el dominio y las tecnologías, mapeo de la funcionalidad expuesta como registro, login, búsqueda, y de los distintos roles de usuario.

Fase 2 — Análisis de vulnerabilidades

Escaneo automatizado, realizar revisión manual enfocada en las áreas más sensibles del caso, que son el control de acceso entre cuentas, inyección ya sea SQL o XSS, gestión de sesión y sus tokens, y lógica de negocio del carrito.

Fase 3 — Explotación

Validación de cada hipótesis empleada en la fase anterior, usando las cuentas de prueba provistas. Ninguna prueba debe alterar datos reales ni afectar la disponibilidad del servicio.

Fase 4 — Post-explotación

Dimensionar el impacto real de cada hallazgo confirmado cómo qué volumen de información de clientes sería accesible, si es posible llegar al panel administrativo, y si existiría posibilidad de persistencia.

Fase 5 — Informe

Consolidar cada hallazgo con evidencia, clasificación de severidad, impacto de negocio y recomendación de remediación priorizada. Se entrega un resumen ejecutivo orientado a la dirección de Aurora Market y un detalle técnico dirigido al equipo de desarrollo para su corrección.

7. Investigación

OWASP Testing Guide

Resulta especialmente útil para Aurora Market porque el incidente que originó la evaluación apunta directamente a una posible falla de control de acceso o autorización, una de las categorías centrales del WSTG.